

ISO/IEC 27042:2015

GUÍA LITE DE INTERPRETACIÓN
ANÁLISIS E INTERPRETACIÓN DE EVIDENCIA DIGITAL

REALIZADO POR:
MY. MERLY YULIETH RIVERA ORTIZ
MY. CRISTIAN MEZA GRANOBLER
MY. COLORADO VALLADALES JHON
MY. SAMIR SALEK
MY. FABER CALDERÓN

ELECTIVA FORENSE DIGITAL
PROFESOR: JAIDER OSPINA NAVAS

1 OBJETIVO Y ALCANCE

OBJETIVO

Estandarizar el análisis e interpretación de evidencia digital potencial en investigaciones de incidentes, garantizando resultados válidos, reproducibles y admisibles ante instancias técnicas y jurídicas.

LÍMITES

- Opera EXCLUSIVAMENTE post-adquisición (inicia donde termina ISO/IEC 27037).
- No cubre: adquisición en escena, respuesta al incidente, admisibilidad legal local ni evidencia cifrada sin clave recuperable.

2 MARCO DE REFERENCIA

ESTÁNDAR	ROL	RELACIÓN CON 27042
ISO/IEC 27037:2012	Identificación, adquisición y preservación de evidencia	PRERREQUISITO — 27042 inicia donde termina 27037
ISO/IEC 27043:2015	Framework general de investigación de incidentes	MARCO SUPERIOR — define clases de proceso donde aplica
ISO/IEC 27041	Idoneidad de métodos investigativos	COMPLEMENTARIO — valida que los métodos sean apropiados
ISO/IEC 27035 (1-3)	Gestión de incidentes de seguridad	CONTEXTO OPERATIVO — 27042 se ejecuta dentro de este proceso
NIST SP 800-86	Técnicas forenses en respuesta a incidentes	REFERENCIA — alineación con framework NIST

3 REQUISITOS PREVIOS Y HERRAMIENTAS

CONDICIONES PREVIAS OBLIGATORIAS

- ✓ Evidencia adquirida bajo ISO/IEC 27037 con hash documentado
- ✓ Autorización formal (judicial/corporativa) con fecha y firma
- ✓ Equipo con competencia demostrada y registrada (§10.2)
- ✓ Entorno de análisis aislado; bloqueador de escritura activo
- ✓ Formulario de cadena de custodia iniciado desde adquisición
- ✓ Plan de investigación con alcance e hipótesis definidos (§5.4)

SOFTWARE FORENSE VALIDADO

HERRAMIENTA	FUNCIÓN (§)
Autopsy 4 / Sleuth Kit	Análisis estático de disco (§7.1) — NIST CFTT
Volatility 3	Análisis de memoria RAM (§7.2)
FTK Imager 4	Imágenes forenses + hash
Hashdeep / sha3sum	Verificación masiva SHA-256/SHA-3
Bulk Extractor 2	Extracción de artefactos (§6.2)
Log2Timeline/Plaso	Supertimeline forense (§6)
Wireshark 4	Análisis de tráfico de red

4 PROCEDIMIENTO PASO A PASO

Regla de imperatividad: Ejecutar en orden. Documentar cada acción en notas contemporáneas. No omitir pasos.

ÁRBOL DE DECISIÓN — Modelo analítico (§7)

¿Sistema **ACTIVO**? → ANÁLISIS EN VIVO (§7.2)

¿Es imageable?

→ Sí: §7.2.3 — Imagen en vivo, luego análisis estático

→ NO: §7.2.2 — Análisis directo; documentar TODA interacción

¿Sistema **INACTIVO**? → ANÁLISIS ESTÁTICO (§7.1)

1. Verificar hash de imagen forense bit a bit

2. Montar imagen en modo read-only (sin escritura)

3. Ejecutar herramientas sobre copia forense (nunca original)

FASE	ACCIÓN IMPERATIVA	SALIDA REQUERIDA
1 — PLANIFICACIÓN (§5)	Definir alcance e hipótesis por escrito. Verificar continuidad de evidencia (§5.2). Configurar entorno aislado. Confirmar hash de recepción.	Plan de investigación + Hash de recepción verificado
2 — ANÁLISIS (§6)	Seleccionar y justificar el método analítico frente a alternativas (§6.2). Validar y documentar cada herramienta con versión y configuración (§6.3). Registrar cada comando y resultado (§6.4).	Registro de análisis + Artefactos extraídos con hash
3 — MODELO (§7)	Aplicar árbol de decisión (ver arriba). Para análisis en vivo: documentar estado del sistema ANTES de actuar. Para estático: trabajar siempre sobre imagen forense.	Imagen forense / Volcado de RAM verificado con hash
4 — INTERPRETACIÓN (§8)	Sintetizar hallazgos dentro de límites acordados (§8.1). Acreditar cada hecho con su artefacto (§8.2). Declarar factores de incertidumbre explícitamente (§8.3).	Conclusiones técnicas: hechos / inferencias / límites

► COMANDOS CRÍTICOS — VERIFICACIÓN DE INTEGRIDAD Y ANÁLISIS:

```
●●● Forensic Terminal
$ sha256sum imagen.E01 | tee imagen.sha256 # Hash SHA-256 pre-análisis
$ mount -o ro,loop imagen.dd /mnt/analisis/ # Montar imagen read-only
$ fls -r -p imagen.E01 # Listar archivos incluyendo eliminados
$ vol -f ram.lime linux.pslist && linux.netstat && linux.malfind # Análisis de memoria RAM
$ log2timeline.py /out/tl.plaso imagen.E01 && psort.py -o l2tcsv /out/tl.plaso > tl.csv #
Supertimeline
```

5 ASEGURAMIENTO DE LA PRUEBA

MOMENTOS OBLIGATORIOS DE HASH		CAMPOS MÍNIMOS — CADENA DE CUSTODIA	
MOMENTO	ALGORITMO	ID de evidencia	EV-2024-001-001
Recepción de evidencia	SHA-256 + comparar con adquisición	Descripción	Tipo, marca, modelo, serial
Antes de montar imagen	SHA-256 (pre-montaje)	Hash SHA-256	Calcular en cada transferencia
Tras cada sesión de análisis	SHA-256 (post-sesión)	Fecha/hora	ISO 8601 con zona horaria
Al exportar cada artefacto	SHA-256 + MD5 (doble)	Responsable	Nombre, cargo y firma
Al emitir informe pericial	SHA-256 del documento final	Motivo transferencia	Justificación del traslado
		Estado del ítem	Íntegro / hash coincide

⚠️

Ruptura de cadena: Acceso no registrado o discrepancia de hash investigador principal.

```
••• Forensic Terminal
$ sha256sum evidencia.E01 > evidencia.sha256
$ sha3sum -a 256 evidencia.E01 > evidencia.sha3
$ hashdeep -r -c sha256 /evidencia/ > manifest.txt
$ hashdeep -r -c sha256 -a -k manifest.txt /evidencia/
```

6 GLOSARIO TÉCNICO-JURÍDICO

TÉRMINO	DEFINICIÓN ISO/IEC 27042	RELEVANCIA
Evidencia Digital (§3.5)	Dato binario determinado relevante mediante análisis	Jerarquía: potencial→digital→legal. Solo la última tiene valor judicial
Interpretación (§3.9)	Síntesis explicativa dentro de límites acordados del conjunto de hallazgos	El perito no puede exceder los límites técnicos del estándar
Repetibilidad (§3.17)	Misma evidencia + mismo entorno = mismo resultado	Garantía para el contra-perito. Sin repetibilidad el método es inválido
Proficiency (§3.16)	Otro equipo con misma evidencia obtiene resultados equivalentes	El tribunal puede exigir prueba de proficiency como condición
Obfuscación (§3.8)	Evidencia oculta/enmascarada deliberada o accidentalmente	Permite explicar la ausencia de evidencia esperada ante tribunal

7 LIMITACIONES ESTÁNDAR

ESCENARIO NO CUBIERTO	ALTERNATIVA
Adquisición en escena forense	ISO/IEC 27037:2012
Respuesta operativa al incidente	ISO/IEC 27035 (1-3)
Evidencia cifrada sin clave	ISO/IEC 27040 + peritaje cripto
Cloud multi-jurisdiccional	ISO/IEC 27050 + MLAT
IoT y hardware propietario	NIST SP 800-101r1
Admisibilidad legal local	Legislación procesal local
Forensic readiness organizacional	ISO/IEC 30121:2015

CASO KERALTY — RANSOMHOUSE

RANSOMWARE SOBRE INFRAESTRUCTURA CRÍTICA DE SALUD
COLOMBIA · NOVIEMBRE 2022
5,9 MILLONES DE AFILIADOS AFECTADOS

CASO DE APLICACIÓN REAL —
ANÁLISIS CRÍTICO

EISO/IEC 27042:2015
ANÁLISIS E INTERPRETACIÓN DE EVIDENCIA DIGITAL

1 CONTEXTO DEL INCIDENTE

1.1 Descripción de los hechos

En la madrugada del 26 de noviembre de 2022, el grupo de ransomware RansomHouse activó un ataque coordinado contra los sistemas de información del Grupo Keralty, la multinacional colombiana de salud que opera bajo las marcas Sanitas EPS, Colsanitas y KeraltyCare, con cobertura a aproximadamente 5,9 millones de afiliados en Colombia. El ataque combinó dos vectores simultáneos, por un lado, el cifrado masivo de archivos en más de 1.800 servidores y estaciones de trabajo, y por otro, la exfiltración de datos hacia un servidor C2 en la red Tor. El acceso inicial se produjo semanas antes mediante credenciales VPN comprometidas de un proveedor externo de TI, aprovechando la ausencia de autenticación multifactor en el segmento de acceso remoto.

El impacto operacional fue inmediato, pues los sistemas de historia clínica electrónica dejaron de funcionar, los portales de consulta de pacientes quedaron inaccesibles y los procesos de agendamiento, facturación y autorización de servicios médicos se interrumpieron durante días. RansomHouse publicó una nota de rescate en su sitio .onion anunciando la exfiltración de 3 TB de datos, incluyendo información personal y médica de pacientes, y exigiendo pago en criptomoneda bajo amenaza de publicación masiva.

Dato crítico: El equipo de TI de Keralty ordenó el apagado de emergencia de los servidores afectados a las 08:45 COT sin preservar previamente el estado de la memoria RAM ni crear imágenes forenses en vivo, eliminando irreversiblemente la evidencia volátil más valiosa del ataque activo.

1.2 Infraestructura afectada

COMPONENTE	DESCRIPCIÓN TÉCNICA	IMPACTO DEL ATAQUE
Servidores de aplicaciones	Windows Server 2016/2019 · Directorio Activo · Historia Clínica Electrónica (HCE) · ERP de facturación	Cifrados con extensión .rhd · Servicios médicos interrumpidos en 130 sedes nacionales
Bases de datos SQL Server	SQL Server 2017 · ~1,8 M registros de pacientes · Datos financieros del sistema de pagos	Tablas cifradas · Imposibilidad de autorizar servicios y procesar reclamaciones
Red corporativa	MPLS entre sedes + VPN para acceso remoto del personal médico y proveedores	Vector de propagación del ransomware entre sedes · Acceso inicial por VPN sin MFA
Servicios en la nube	Azure AD (autenticación) · SharePoint Online · Backup parcial en Azure Blob	Azure AD comprometido para movimiento lateral · Logs de Azure con retención de solo 60 días
Sistemas de seguridad	SIEM QRadar activo · EDR Cylance desplegado en solo 40% de endpoints	Alertas generadas pero no respondidas en tiempo · 60% de endpoints sin visibilidad de EDR

1.3 Cronología de los hechos observados

FECHA / HORA (COT)	EVENTO	ARTEFACTO DISPONIBLE	OBSERVACIÓN FORENSE
~Oct 2022 (fecha estimada)	-Acceso inicial mediante credenciales VPN comprometidas de proveedor externo. -Sin MFA activo.	Logs VPN Azure AD sign-in	-Fecha exacta desconocida. -Retención de logs VPN: 30 días. -Período pre-ataque no recuperable
Nov 1–25, 2022 (período de dwell)	-Reconocimiento con BloodHound -Extracción de credenciales con Mimikatz -Movimiento lateral con PsExe -Exfiltración progresiva hacia C2 Tor	Prefetch de herramientas Logs SIEM parciales pcap firewall	-Dwell time estimado: ~3-4 semanas -SIEM generó alertas no atendidas
Nov 26, 2022 ~01:30 COT	-Despliegue masivo del payload RansomHouse -Cifrado de 1.800+ endpoints con extensión .rhd -Eliminación de VSS Shadow Copies -Exfiltración de 3 TB hacia nodo Tor (185.220.101.47)	Imágenes E01 Logs de eventos Windows ID 4688 pcap del firewall	3 de 7 servidores críticos con logs truncados por técnica antiforense
Nov 26, 2022 06:15 COT	-Detección por operaciones: sistemas HCE inaccesibles -Llamadas masivas de sedes regionales	Tickets de soporte Registros de llamadas	Evidencia administrativa: Admisible como contexto del incidente
Nov 26, 2022 08:45 COT	DECISIÓN CRÍTICA: apagado de emergencia de 34 servidores sin preservación forense de RAM ni imagen en vivo	Correo interno del CTO: 'Apagar todo de inmediato'	-FALLA F-01: pérdida irreversible de evidencia volátil -Violación directa de §7.2.1 ISO/IEC 27042
Nov 26–27, 2022	-RansomHouse publica nota de rescate en sitio .onion -Anuncia 3 TB exfiltrados -Amenaza publicación de datos de pacientes en 72 horas	Capturas OSINT del portal .onion	Evidencia pública: Confirma exfiltración pero no permite identificar el contenido específico
Nov 28, 2022	-Vinculación de la Fiscalía General de la Nación -Inicio de investigación penal bajo Ley 1273/2009 Art. 269A	Resolución de inicio de investigación	-Inicio formal de cadena de custodia judicial -Las evidencias anteriores quedan en zona gris de admisibilidad
Nov 28 – Dic 15, 2022	-Recolección forense de 31 servidores (3 no recuperados) -Extracción de logs SIEM -Análisis de pcap (capturas de 72h previas)	Imágenes .E01 Logs SIEM pcap	Cadena de custodia formal activa desde este punto
Mar 2023	-SIC abre investigación administrativa por violación de Ley 1581/2012 (datos personales de pacientes)	Resolución SIC 15243/2023	-Segunda instancia jurídica -Plazos probatorios distintos a los del proceso penal

1.4 Artefactos y evidencias disponibles

ID	TIPO DE ARTEFACTO	ESTADO DE INTEGRIDAD	VALOR PROBATORIO
EV-01	Imágenes forenses .E01 31 servidores Windows Server (~47 TB)	VERIFICADA - SHA-256 documentado	Alto: Artefactos de malware, prefetch, MFT, registro de Windows
EV-02	Volcados RAM, adquiridos post-reinicio (3 servidores)	COMPROMETIDA- adquirida después del reinicio	Bajo: Procesos del ataque ausentes al momento de adquisición
EV-03	Logs SIEM QRadar exportados ~2,1 GB · 72h previas	PARCIAL - 3 nodos sin log forward durante el ataque	Medio: Gaps de 5h en período crítico 01:00–06:00 COT
EV-04	Capturas pcap del firewall perimetral - 340 GB	VERIFICADA - SHA-256 documentado	Alto: Evidencia de exfiltración hacia IP C2 y tráfico de reconocimiento
EV-05	Binarios RansomHouse en cuarentena EDR - 47 muestras	VERIFICADA - MD5 + SHA-256 documentados	Muy alto: Permite reconstruir comportamiento e identificar IOCs
EV-06	Correos internos del equipo TI PST Exchange - 14.000 correos	VERIFICADA	Medio: Decisiones operativas · Relevante para análisis de negligencia
EV-07	Logs Azure AD - 90 días exportados vía Microsoft Purview	PARCIAL - Sin datos previos a 60 días antes del incidente	Alto: Confirma vector de acceso inicial y movimiento lateral en nube
EV-08	3 servidores no preservados (apagados sin imagen forense)	INEXISTENTE - Pérdida irreversible	Nulo: Incluyen logs de autenticación del período de dwell

2 ANÁLISIS FORENSE

2.1. ¿Cómo se aplicó el estándar de recolección de pruebas?

La investigación forense fue conducida por el equipo de Verizon RISK Team en colaboración con el Servicio Secreto de EE.UU. y la Fiscalía General de la Nación. La aplicación de ISO/IEC 27042:2015 fue parcial, pues el análisis post-adquisición siguió el estándar en sus modelos analíticos (§7.1 estático y §7.2 en vivo), pero la recolección previa al arribo del equipo forense presentó fallas críticas de cadena de custodia que comprometieron la integridad de parte de la evidencia. El estándar pudo aplicarse plenamente solo a los 31 servidores correctamente preservados (EV-01).

MODELO ISO/IEC 27042	APLICACIÓN EN EL CASO	HALLAZGOS CLAVE	LIMITACIÓN DEL ESTÁNDAR
Análisis estático (§7.1) Imágenes E01 sobre 28 servidores	Verizon RISK montó imágenes .E01 en modo read-only. Herramientas: Autopsy, Volatility (sobre EV-02), Bulk Extractor. Cada proceso documentado con versión de herramienta y hash de salida.	► Persistencia: clave de registro Run apuntando a svchost32.exe ► Prefetch de mimikatz.exe (run: 2022-11-26 01:34:12 UTC · Count: 3) ► VSS Shadow Copies eliminadas (vssadmin.exe en prefetch) ► 847 archivos cifrados .rhd en 45 directorios del MFT	EV-02 inválido: volcados RAM post-reinicio no permiten correlacionar procesos activos con artefactos de disco (§7.2.1 no aplicable retroactivamente).
Análisis en vivo (§7.2) No ejecutado en momento crítico	El análisis en vivo fue imposible: los 34 servidores fueron apagados sin protocolo forense antes del arribo del equipo. El correo del CTO (EV-06) documenta la decisión unilateral de apagado.	► Pérdida de: procesos activos, conexiones de red, claves de cifrado en RAM, tokens Kerberos ► Sin posibilidad de reconstruir el proceso de exfiltración activo ► Identidad técnica del operador: no determinable con certeza	Violación directa de §7.2.1: el estándar exige documentar el estado del sistema ANTES de cualquier acción. El apagado sin preservación es incompatible con el estándar.
Análisis de red (pcap EV-04) Análisis estático complementario	Capturas del firewall perimetral (72h previas) analizadas con Wireshark y tshark. Correlación con logs SIEM para reconstruir la timeline del ataque.	► Tráfico a 185.220.101.47:443 (nodo Tor) durante 4h 23m ► ~3,2 TB exfiltrados por HTTPS/Tor (volumen, no contenido) ► Escaneo SMB (TCP 445) desde 10.20.5.14 — 72h antes del cifrado ► 4 saltos de movimiento lateral identificados vía PsExec	Límite §8.3: el cifrado de capa de transporte (TLS 1.3 sobre Tor) impide determinar el contenido específico exfiltrado. Solo el volumen es verificable.

2.2. Técnicas Antiforenses de RansomHouse Identificadas

Impacto sobre la investigación: RansomHouse aplicó al menos 5 técnicas deliberadas para obstaculizar el análisis forense posterior. Su identificación bajo §6.2 (principios de análisis) es obligatoria para contextualizar por qué parte de la evidencia es irre recuperable y qué conclusiones están fuera de los límites del perito (§8.3).

TÉCNICA	MECANISMO	IMPACTO EN EL ANÁLISIS	EVIDENCIA RESIDUAL
Eliminación de Shadow Copies	vssadmin delete shadows /all wmic shadowcopy delete	Impide recuperar versiones previas de archivos cifrados.	Prefetch de vssadmin.exe Logs ID 4688
Cifrado de logs de eventos	Ransomware cifró archivos .evtx en C:\Windows\System32\winevt\	Logs de eventos Windows irre recuperables en 3 servidores críticos.	Metadatos MFT Timestamps de última modificación
Limpieza de herramientas post-uso	Eliminación de mimikatz.exe y herramientas de reconocimiento tras ejecución	Binarios no disponibles en disco. Solo detectables por prefetch.	Archivos .pf en C:\Windows\Prefetch\
Exfiltración sobre Tor (HTTPS)	Túnel TLS 1.3 sobre red Tor, contenido inspeccionable imposible	No es posible determinar qué datos específicos fueron exfiltrados.	Pcap EV-04: IPs Tor, volumen, duración de sesiones
Eliminación de logs de Azure AD	Actores borraron entradas de auditoría en Azure AD post-compromiso	Acceso inicial no completamente reconstruible. Brecha de 30 días.	Microsoft Purview: meta-evidencia de las acciones de borrado

2.3 Fallas en la Cadena de Custodia Documentadas

FALLA	DESCRIPCIÓN	SECCIÓN 27042 VULNERADA	IMPACTO SOBRE ADMISIBILIDAD
F-01	Apagado de 34 servidores sin preservar RAM ni crear imagen forense en vivo antes del arribo del equipo forense	§7.2.1 - Documentación previa a cualquier acción sobre sistema activo	Pérdida irreversible de evidencia volátil. Posible obstrucción involuntaria. Las preguntas sobre atribución del atacante quedan sin respuesta técnica.
F-02	3 servidores críticos no preservados, sin imagen .E01 disponible (EV-08)	§5.2 - Continuidad de la evidencia	Brecha probatoria ante Fiscalía: no puede demostrarse qué datos existían en esos servidores al momento del ataque.
F-03	Logs SIEM con gap de 5h (01:00 - 06:00 COT del 26 nov) por nodos sin reenvío activo	§6.4 - Registro completo de cada proceso analítico	Imposibilidad de reconstruir la timeline completa. La defensa puede argumentar actividad no documentada en el período gap.
F-04	Volcados de RAM adquiridos post-reinicio, no reflejan estado activo del ataque (EV-02)	§7.2.3 Sistemas imageables deben capturarse ANTES de modificación	EV-02 sin valor probatorio para el estado activo. El análisis de memoria es inútil para reconstruir procesos del ataque.
F-05	Cadena de custodia formal iniciada 2 días después del incidente (Nov 28 - llegada Fiscalía)	§5.2 - Continuidad desde el primer contacto con la evidencia	EV-01 a EV-04 (recolectados antes del Nov 28) tienen cadena de custodia incompleta. Su admisibilidad puede ser impugnada por la defensa bajo Art. 277 CPP.

2.4. Comandos Clave del Análisis Ejecutado

```
●●● forensic@lab - Evidencia Keralty / RansomHouse
$ # Verificar hash de imagen antes de montar (§5.2 - continuidad)
$ sha256sum keralty_srv01.E01 | tee keralty_srv01.sha256
→ e3b0c44298fc1c149afb4c8996fb924... keralty_srv01.E01: OK

$ # Análisis de persistencia - registro malicioso (EV-01) (§7.1)
$ reg load HKLM\TEMP /mnt/analisis/Windows/System32/config/SYSTEM
$ reg query 'HKLM\TEMP\CurrentVersion\Run'
→ svchost32 = C:\ProgramData\svc32.exe [ANOMALÍA detectada]

$ # Prefetch de herramientas del atacante (EV-01)
$ python3 prefetch.py /mnt/analisis/Windows/Prefetch/ | grep -E 'MIMIKATZ|VSSADMIN|PSEXEC'
→ MIMIKATZ.EXE Last run: 2022-11-26 01:34:12 UTC Count: 3
→ VSSADMIN.EXE Last run: 2022-11-26 01:41:05 UTC Count: 1 [eliminación Shadow Copies]

$ # Análisis de exfiltración en pcap (EV-04)
$ tshark -r firewall_nov26.pcap -Y 'ip.dst==185.220.101.47' -T fields -e frame.time -e ip.len | wc -l
→ 847.293 paquetes | ~3,2 TB hacia nodo Tor | Duración: 4h 23m

$ # Supertimeline - correlación de todos los artefactos (§6.4)
$ log2timeline.py /out/keralty.plaso /mnt/analisis/ && psort.py -z America/Bogota -o l2tcsv /out/keralty.plaso > timeline.csv
```

3 VEREDICTO Y RESULTADO

3.1. ¿Fue la Evidencia Digital Declarada Admisible?

La admisibilidad de la evidencia digital en el caso Keralty fue diferenciada por instancia jurídica y por ítem de evidencia. La aplicación, incluso parcial, de los principios de ISO/IEC 27042:2015 fue determinante para sostener la validez del análisis forense ante las diferentes autoridades.

La evidencia con cadena de custodia verificada (EV-01, EV-04, EV-05) fue admitida; la evidencia con fallas documentadas (EV-02, EV-08) fue excluida o asignada valor probatorio reducido.

INSTANCIA	PROCESO	ADMISIBILIDAD	FUNDAMENTO
Fiscalía General de la Nación	Investigación penal Ley 1273/2009 Art. 269A - Acceso abusivo a sistema informático	PARCIAL: EV-01, EV-04 y EV-05 admitidos · EV-02 y EV-08 excluidos	La cadena de custodia de EV-01 y EV-04 fue verificada con SHA-256 desde Nov 28. EV-02 rechazado por haber sido adquirido post-reinicio (§7.2.3). EV-08 inexistente por la falla F-01.
SIC — Superintendencia de Industria y Comercio	Investigación administrativa Ley 1581/2012 - Protección de datos personales de pacientes	ADMITIDA con observaciones: Apertura de investigación formal en Mar 2023	La SIC valoró el conjunto probatorio en su totalidad. Las fallas de cadena de custodia se registraron como agravante de negligencia organizacional, no como causal de exclusión de evidencia en el régimen administrativo sancionatorio.
Proceso civil (demandas de pacientes)	Acciones de grupo promovidas por afiliados afectados - Daños y perjuicios	EN CURSO: Evidencia admitida como base del daño demostrado	Los pcap (EV-04) y los logs SIEM (EV-03) fueron suficientes para acreditar la exfiltración masiva sin necesidad de identificar el contenido específico. El volumen (3,2 TB) fue evidencia suficiente del riesgo de daño.

3.2. Factores Determinantes de la Admisibilidad

FACTORES QUE FAVORECIERON LA ADMISIBILIDAD

- ✓ Hashes SHA-256 documentados para EV-01 y EV-04 desde el momento de recolección.
- ✓ Herramientas forenses validadas (Autopsy, Volatility, Wireshark) con versión y configuración registradas bajo §6.3.
- ✓ Análisis en vivo parcialmente justificado mediante árbol de decisión §7.2 para los servidores que sí permanecieron activos.
- ✓ Informe pericial con metodología explícita y declaración de limitaciones bajo §8.3.
- ✓ Múltiples equipos (Verizon + Fiscalía) con hallazgos consistentes — evidencia de proficiency §3.16.
- ✓ Supertimeline con correlación temporal de múltiples fuentes, con zona horaria COT documentada.

FACTORES QUE DEBILITARON LA ADMISIBILIDAD

- X Apagado de 34 servidores sin preservación forense previa (F-01) — pérdida de evidencia volátil crítica.
- X Cadena de custodia formal iniciada 48 horas después del incidente (F-05) — EV-01 a EV-04 en zona gris de admisibilidad.
- X EV-02 (volcados RAM post-reinicio) excluida por no reflejar el estado del ataque (§7.2.3 no cumplido).
- X Gaps de 5 horas en logs SIEM (F-03) — la defensa pudo argumentar actividad no documentada en ese período.
- X 3 servidores sin imagen (F-02) — brecha probatoria sobre qué datos existían en esos sistemas.
- X Técnicas antiforenses de RansomHouse: imposible determinar el contenido exacto de los 3,2 TB exfiltrados.

3.3. Resultado y Lecciones del Caso

Lección forense central: La evidencia digital NO fue invalidada en su totalidad porque el equipo que hizo la recolección post-arribo siguió los principios de ISO/IEC 27042 (hashes, herramientas documentadas, metodología explícita). Las fallas ocurrieron ANTES del arribo del equipo forense, durante las decisiones operacionales de TI. Esto demuestra que el estándar protege la investigación cuando se aplica, pero no puede compensar la ausencia de forensic readiness organizacional.

RESULTADO	DETALLE
Investigación penal (Fiscalía)	Investigación activa bajo Ley 1273/2009 Art. 269A. El anonimato técnico del operador de RansomHouse (sin identidad atribuible por la evidencia forense disponible) ha dificultado la imputación de cargos. La cooperación internacional con el FBI está en curso bajo MLAT.
Proceso SIC (Ley 1581/2012)	La SIC inició formalmente investigación en marzo de 2023. Keralty enfrenta sanciones por no haber implementado medidas de seguridad adecuadas para proteger los datos personales de sus 5,9 millones de afiliados.
Impacto reputacional y operacional	Keralty reportó pérdidas operacionales por más de \$15 millones USD durante las semanas de interrupción de servicios. La marca sufrió un impacto reputacional significativo, con deserción de afiliados documentada en trimestres posteriores al ataque.
Valor del estándar ISO/IEC 27042	La aplicación del estándar en el análisis post-adquisición permitió sostener la validez de EV-01 y EV-04 ante la Fiscalía y la SIC. La ausencia de un protocolo forense previo (forensic readiness bajo ISO/IEC 30121) fue la causa raíz de las fallas F-01 a F-05, no el estándar de análisis en sí.